

PDPA Consent Flow Coordination

ShopeePay (2021–2022) — connecting hands-on work experience to the Governance, Risk & Compliance (GRC) framework

Papras (Phatt) Nualchaem | September 2026

Executive Summary

- Drove and coordinated the design of a PDPA-compliant user consent flow across three functions — Legal, Product and UX/UI — in Thailand and Singapore over roughly two months, ahead of ShopeePay's launch of email direct marketing (EDM).
- Delivered the campaign with a working unsubscribe mechanism and an agreed sending-frequency framework, giving users a documented, low-friction way to withdraw consent and limiting over-communication.
- The work maps onto all three GRC pillars in practice rather than in theory: cross-team decision structures, operational risk control, and regulatory compliance.

Project Snapshot

Role	Owned Media Executive (Marketing & Legal Liaison)
Objective	Coordinate and design a PDPA-compliant consent flow for marketing email (EDM)
Scope	Cross-border coordination between the ShopeePay Thailand and Singapore teams
Approach	Cross-functional working sessions with Legal, Product and UX; consent UX design; campaign governance
Timeline	Approximately two months from first working session to campaign launch
Scale	First campaign sent to approximately 300,000 users

A Quick Primer: What Is GRC?

GRC stands for Governance, Risk Management and Compliance — the framework organisations use to keep work pointed in the right direction, keep risk under control, and stay within the law. The three pillars reinforce one another.

Governance	Risk Management	Compliance
Defines who holds decision-making authority and what process must be followed when personal data is collected or used. Here: a working process across Legal, Product and UX spanning two markets.	Assesses and reduces the likelihood or impact of harm — for example, emailing users too often, or being mistaken for a phishing attempt.	Makes sure day-to-day practice matches what the law requires — for example, PDPA rules on obtaining consent and offering an easy way to withdraw it.

What Was Done — Grouped by GRC Pillar

1) Governance — building a shared decision-making structure

- Initiated and chaired the working sessions between the Thailand and Singapore teams, acting as the single coordination point aligning Legal, Product and UX/UI stakeholders on one consistent approach.

Why this is Governance: it defines who is involved in a decision and builds a reliable channel for information to move between teams.

- Contributed to the in-app consent design and worked with the Legal team on the Privacy Notice, over three rounds of review, so that both aligned with PDPA requirements.

Why this is Governance: it translates written policy into a working user experience, bridging Legal and Product.

2) Risk Management — reducing operational and reputational exposure

- Drove the decision to send campaigns under a consistent sender identity — the display name “ShopeePay” on a dedicated sending subdomain under the group's official domain (news@email.shopee.co.th) — so recipients could recognise the brand and verify the sender.

Why this is Risk Management: the display name drives recognition but is trivial to spoof; the authenticated subdomain is the part a recipient or a mail system can actually verify. Pairing the two lowers the risk of brand impersonation and supports user trust.

- Negotiated fixed monthly sending slots agreed across teams, balancing marketing reach against user disruption.

Why this is Risk Management: frequency capping is an operational control that lowers the chance users feel over-marketed to and either complain or withdraw consent.

3) Compliance — turning PDPA requirements into practice

- Led the delivery of ShopeePay's first EDM campaign designed for PDPA compliance from the ground up.

Why this is Compliance: it takes a legal requirement — PDPA Section 19, on obtaining consent — and embeds it in an actual business process rather than leaving it as policy on paper.

Timing note: Thailand's PDPA was enacted in 2019, but full enforcement was repeatedly postponed and took effect on 1 June 2022. This campaign launched in October 2021, so the consent flow was built ahead of the enforcement date rather than in response to it.

- Drove the design of the opt-out mechanism and the consent-withdrawal workflow with Legal and UX, so users stayed in control of their own data.

Why this is Compliance: PDPA Section 19 requires that withdrawing consent be as easy as giving it. The campaign email carried Privacy Policy and Terms & Conditions links plus an unsubscribe option — a direct match for that requirement.

Outcomes & Business Impact

Outcome	Business Value	GRC Pillar
Launched ShopeePay's first PDPA-compliant EDM campaign	Opened a new marketing channel, reaching approximately 300,000 users in the first send, with legal and reputational risk assessed and controlled	Compliance
Established an agreed, predictable sending framework	Limited over-communication and gave users a documented, low-friction opt-out path	Risk Management
Left behind a repeatable compliance process	Later campaigns could reuse the flow instead of redesigning it each time	Governance

GRC Skills Demonstrated

- **Cross-functional stakeholder governance** — convening and aligning stakeholders across two markets to reach a shared decision.
- **Policy-to-practice translation** — turning legal requirements into a working step inside the product.
- **Risk-based control design** — building controls such as an identifiable sending domain and frequency caps.
- **Regulatory compliance implementation** — putting PDPA consent and withdrawal requirements into actual practice.
- **Change and communication management** — negotiating and communicating a process change across several teams.

Where This Sits Within a Real-World GRC Framework

Viewed through the Three Lines Model, a risk governance framework widely used in organisations, this role sat in the 1st Line — business and marketing operations — but worked closely with the 2nd Line, Legal and Compliance, to

embed controls into the process from the start rather than checking for problems after the fact. That is the pattern organisations with mature data governance tend to follow.

The approach also aligns with international privacy standards such as ISO/IEC 27701 (Privacy Information Management System) and the NIST Privacy Framework, both of which emphasise managing the full consent lifecycle — from requesting consent, to using it, to honouring its withdrawal.

Compliance Elements Implemented

The campaign email that went out in October 2021 carried the following elements, which are what made the campaign PDPA-compliant in practice rather than on paper:

- A link to the Privacy Policy.
- A link to the Terms & Conditions.
- A clearly visible unsubscribe link.
- A consistent sender identity: the display name “ShopeePay” on a dedicated subdomain under the group's official domain (news@email.shopee.co.th).

A redacted sample of the campaign email can be shared on request; recipient details are removed to preserve confidentiality.

Lessons Learned

- **Compliance and commercial incentives pull in opposite directions.** Marketing did not want a prominent unsubscribe path; PDPA Section 19 requires that withdrawing consent be as easy as giving it. That disagreement is not settled by quoting the law at people.
- **Translate impact, not rules.** Leadership was unlikely to accept “the law requires it” on its own, so the easy opt-out had to be presented in terms the business already used: regulatory exposure, complaint volume and the cost of getting it wrong later. Framing the requirement as risk reduction is what made the decision defensible on commercial grounds as well as legal ones.
- **The design is where the conflict is resolved.** Product had to build a flow that was genuinely easy to use for withdrawal while still serving the marketing objective. A control that is hostile to use does not meet the requirement in substance even when it technically exists — which is why the consent design, not the Privacy Notice, was the real deliverable.

Key Takeaway for Reviewers

The job title never used the words GRC or Compliance Officer, but the work covered all three pillars in practice — cross-team coordination, risk control, and compliance with personal data protection law.

The strength worth highlighting is direct, hands-on experience turning a legal requirement into a working process at the product and marketing level — a skill that connects Legal, Business and Technology, which is the core of GRC work.

Reference: Personal Data Protection Act B.E. 2562 (2019), Section 19 — consent and withdrawal of consent. Internal operational details have been generalised to preserve former-employer confidentiality.